Lorsque un attaquant tente d'accéder à un fichier en utilisant son nom connu, IIS va fouiller le dur dur et va renvoyer une réponse différente si le fichier existe ou non même si l'accès direct au dossier est interdit, en automatisant ces requêtes et en utilisant les caractères joker (A*~1* -> AD*~1*) un outil automatisé peut valider les lettres unes par unes et reconstituer la structure cachée du serveur web en quelques secondes ou plus comme, Le numéro après tild est 1 et augmentera si le fichier en la même "structure nommé) des 6 premiers caractères.

Attaquer LDAP :

LDAP est un protocole qui permet d'accéder et gérer des informations dans un annuaire. Cet annuaire est une base de donnée hiérarchique qui centralise des informations sur les ressources d'un réseau, comme les utilisateurs, les groupes et les ordinateurs

Il fonctionne sur un modèle client-serveur, Le serveur LDAP (Comme OpenLDAP et Active Directory) stocke et gère l'annuaire, Le client LDAP (comme l'outil en ligne de commande ldapsearch ou une application web) envoie des requêtes pour interagir avec cet annuaire

Quand un client veut interagir avec le serveur, il construit une requête qui contient plusieurs éléments : il spécifie l'opération à effectuer (bin: Authentification, search : Recherche d'entrées, ou encore, add, delete, modify), les paramètres de la requête par exemple pour une requête on spécifie le DN de la base, un filtre pour trouver des entrées et un ID pour que le client puisse associer la réponse à la bonne requête

Rien de mieux qu'un exemple de requête avec ldapsearch :

```
figentpathogene@parrot ~$ ldapsearch -H ldap://ldap.example.com:389 -D "cn=admin,dc=example,dc=com" -w secret123 -b "ou=people,dc=example,dc=com" "(mail=john.doe@example.com)"
```

Décomposons cette commande :

- Se connecter au serveur ldap.example.com sur le port 389
- S'authentifier en tant que cn=admin, dc=example, dc=com avec mdp secret
- Rechercher sous le DN (Distinguished Name en gros identifiant complet d'une entrée)
- Utiliser le filtre (mail=johndoe@example.com) pour trouver les entrées qui possèdent cet adresse mail

La réponse du serveur inclura le DN de l'entrée qui correspond aux critères de recherche ainsi que ses attributs et valeurs

L'Injection LDAP : Une attaque qui exploite les applications web utilisant LDAP pour l'authentification et le stockages d'informations utilisateurs, le but étant d'injecter du code ou des caractères spéciaux dans la requête pour altérer le fonctionnement de l'application un peu comme les injections SQL

- `*` : une astérix qui peut correspondre à n'importe quel nombre de caractères
- `()` : les parenthèses peuvent grouper des expressions
- `|` : peux effectuer un OU logique
- `&` : peux effectuer un ET logique

`(cn=*)` : Des valeurs d'entrées qui tentent de contourner des contrôle d'authentification ou d'autorisation qui en injectant des conditions qui s'évaluent toujours à true peuvent être utilisées.

Tout comme pour les injections SQL c'est à la patience la persévérance et la capacité à déduire le fonctionnement, que le hacker parviendra à trouver et surtout parviendra à exploiter une telle faille. Bon courage, Bon je m'égare, je m'égare...